Phishing Email Analysis

1. Introduction

This research focuses on analyzing a suspicious email identified as a potential phishing attempt.
The objective is to examine the email headers, sender information, embedded URLs, domain reputation, and overall structure to determine whether the email is legitimate or malicious.

By analyzing cyber threat intelligence results, email metadata, and Indicators of Compromise (IOCs), this research demonstrates how attackers craft phishing campaigns to steal user credentials, deliver malware, or impersonate trusted services.
The findings support better detection, prevention, and user awareness practices within organizations.

Microsoft account

Unusual sign.in activity

We detected something unusual about a recent sign-in to the Microsoft account phishing@pot.

Sign-in details

Country/region: **Russia/Moscow**

IP address: **103.225.77.255**

Date: **Fri, 08 Sep 2023 05:46:57 +0000**

Platform: **Windows 10**

Browser: **Firefox**

A user from **Russia/Moscow** just logged into your account from a new device, If this wasn't you, please report the user. If this was you, we'll trust similar activity in the future.

Report The User

To opt out or change where you receive security notifications, click here.

Thanks,
The Microsoft account team

2. Identifying the Source of the Phishing Email

The phishing email shows several red flags in the header and body, indicating impersonation and malicious intent.

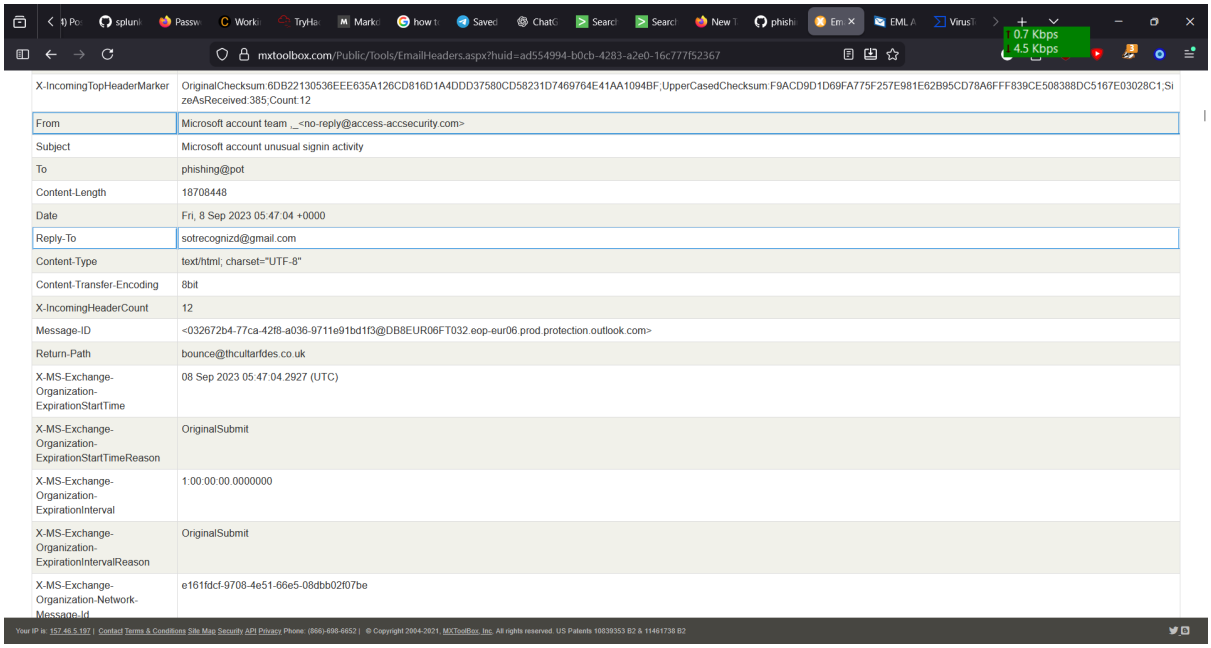
2.1. From and Reply-To Address Mismatch

- **From Address:** no-reply@access-accsecurity.com

Reply-To Address: sotrecognizd@gmail.com

This mismatch is a common phishing technique used to redirect victims to an attacker-controlled mailbox.

Conclusion:
The sender is attempting to impersonate a service (Microsoft account security), but replies are routed to a personal Gmail account.



mxtoolbox.com/Public/Tools/EmailHeaders.aspx?huid=ad554994-b0cb-4283-a2e0-16c777f52367

X-IncomingTopHeaderMarker	OriginalChecksum:6DB22130536EEE635A126CD816D1A4DDD37580CD58231D7469764E41AA1094BF;UpperCasedChecksum:F9ACD9D1D69FA775F257E981E62B95CD78A6FFF839CE508388DC5167E03028C1;SizeAsReceived:385;Count:12
From	Microsoft account team _<no-reply@access-accsecurity.com>
Subject	Microsoft account unusual signin activity
To	phishing@pot
Content-Length	18708448
Date	Fri, 8 Sep 2023 05:47:04 +0000
Reply-To	sotrecognizd@gmail.com
Content-Type	text/html; charset="UTF-8"
Content-Transfer-Encoding	8bit
X-IncomingHeaderCount	12
Message-ID	<032672b4-77ca-42f8-a036-9711e91bd1f3@DB8EUR06FT032.eop-eur06.prod.protection.outlook.com>
Return-Path	bounce@thcultarfdes.co.uk
X-MS-Exchange-Organization-ExpirationStartTime	08 Sep 2023 05:47:04.2927 (UTC)
X-MS-Exchange-Organization-ExpirationStartTimeReason	OriginalSubmit
X-MS-Exchange-Organization-ExpirationInterval	1:00:00:00.0000000
X-MS-Exchange-Organization-ExpirationIntervalReason	OriginalSubmit
X-MS-Exchange-Organization-Network-Message-Id	e161fdcf-9708-4e51-66e5-08dbb02f07be

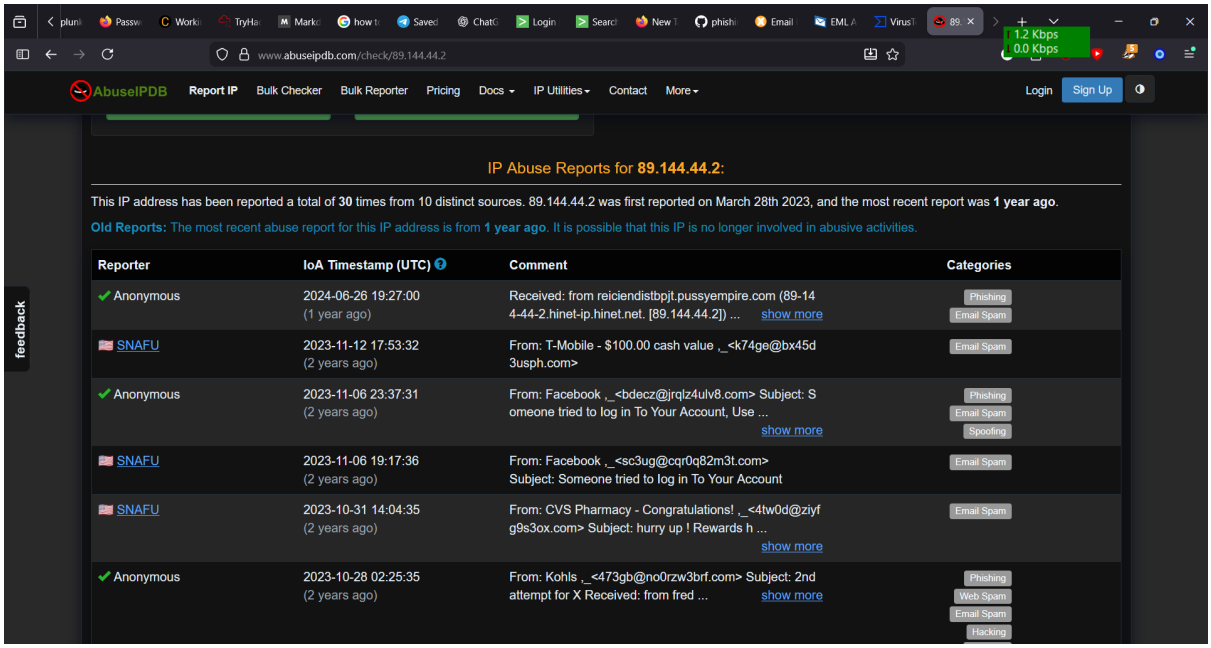
Your IP is: 157.46.5.197 | Contact Terms & Conditions Site Map Security API Privacy Phone: (866)-698-6652 | © Copyright 2004-2021, MXToolBox, Inc. All rights reserved. US Patents 10839353 B2 & 11461738 B2

2.2. Malicious Sender IP Address

The originating IP **89.144.44.2** was analyzed through AbuseIPDB and flagged for:

- Phishing
- Email spoofing
- Spam activity

This confirms that the sender is using an untrusted or compromised infrastructure.



Conclusion:

The sender's infrastructure is already associated with malicious behavior and cannot be considered legitimate.

2.3. Malicious Domain and URL Indicators

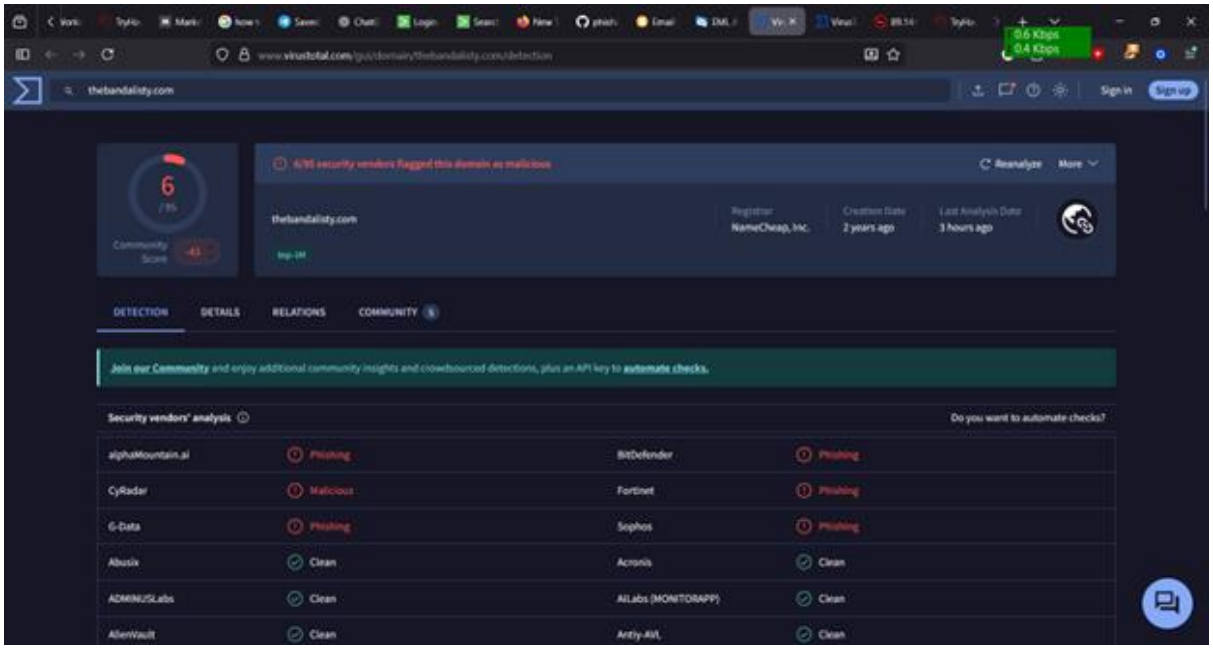
The email contains a URL and domain obtained from the email body:

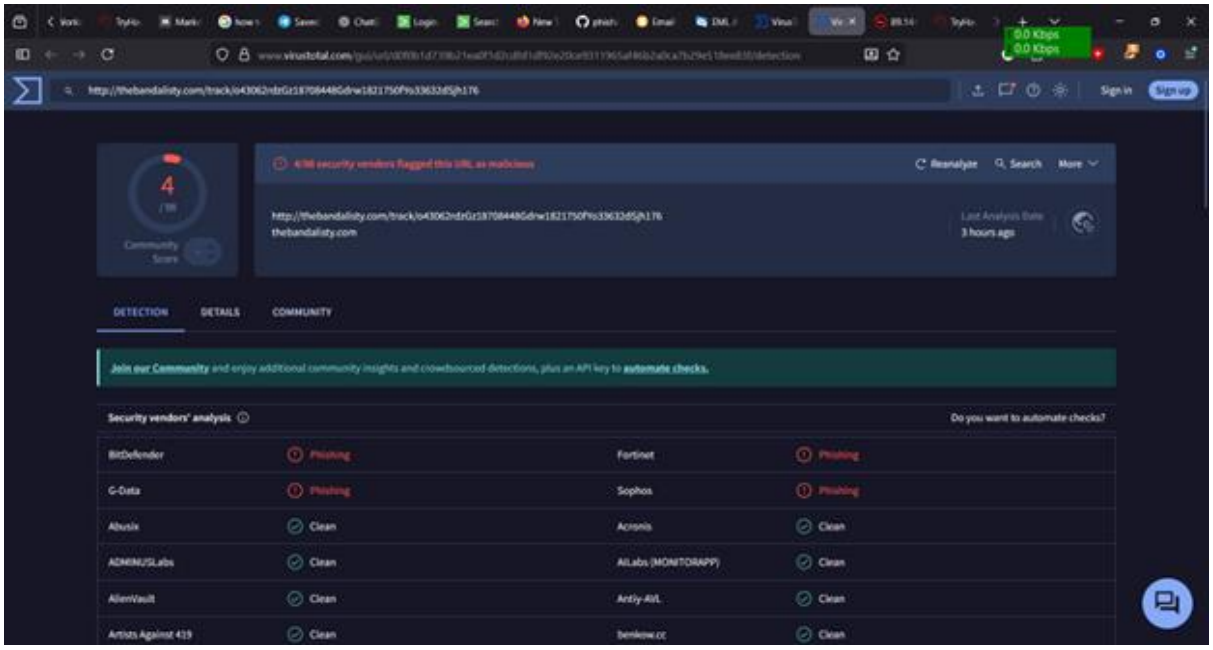
- **Domain:** thebandalisty.com
- **URL:** http://thebandalisty.com/track/o43062rdzGz18708448Gdrw1821750fYo33632dSjh176

VirusTotal flagged both as phishing and malicious.

Typical behavior of such phishing URLs:

- Fake login pages for credential harvesting
- Tracking strings to identify victim clicks
- Redirects to malicious payloads or data-stealing forms





Conclusion:

The URL is designed to mislead users into entering credentials on an attacker-controlled site.

2.4. Email Subject and Social Engineering Indicators

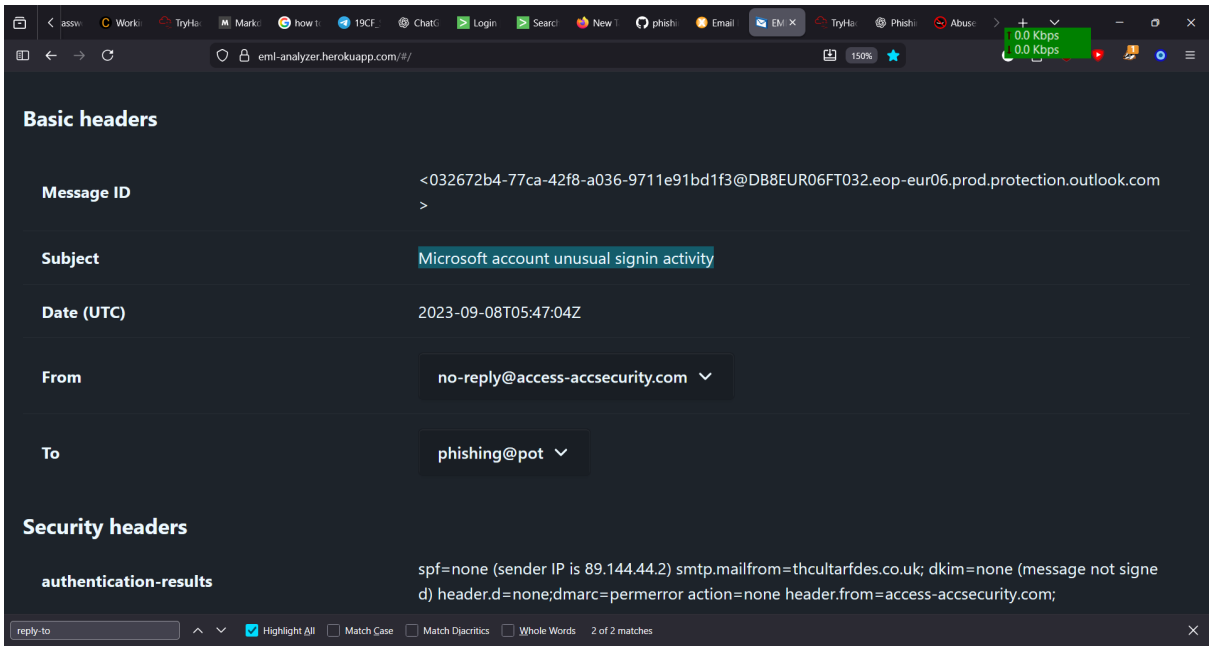
Subject: *Microsoft account unusual signin activity*

The subject is crafted to:

- Create urgency

- Trigger emotional response
- Make users click links without verifying authenticity

The attackers impersonate Microsoft Security notifications to increase success rate.



Microsoft account

Unusual sign.in activity

We detected something unusual about a recent sign-in to the Microsoft account phishing@pot.

Sign-in details

Country/region: **Russia/Moscow**

IP address: **103.225.77.255**

Date: **Fri, 08 Sep 2023 05:46:57 +0000**

Platform: **Windows 10**

Browser: **Firefox**

A user from **Russia/Moscow** just logged into your account from a new device, If this wasn't you, please report the user. If this was you, we'll trust similar activity in the future.

Report The User

To opt out or change where you receive security notifications, click here.

Thanks,
The Microsoft account team

Conclusion:
The subject line is a classic credential-harvesting phishing lure.

3. Behaviour and Intent of the Phishing Email

Although this is not malware-based like ransomware or trojans, phishing emails carry their own behavioral patterns.

3.1. Impersonation Attempt

The attacker pretends to be Microsoft by:

- Using security-related subject lines
- Mimicking account alerts
- Using professional tone

However, domain and reply-to addresses expose the deception.

3.2. Credential Harvesting Mechanism

The embedded URL likely leads to:

- A fake Microsoft login page
- HTML/CSS mimicking Microsoft branding
- A backend script that stores entered credentials

Once harvested, attackers may:

- Gain access to email accounts
- Reset passwords
- Conduct internal phishing
- Perform Business Email Compromise (BEC)
- Access cloud assets (Azure, OneDrive, M365)

3.3. Potential Organizational Impact

If a user clicked the link and submitted credentials, attackers could:

- Access corporate email
- Steal sensitive data
- Impersonate employees internally
- Request fraudulent payments
- Bypass MFA through token theft (in advanced cases)

Conclusion:
This phishing attempt poses a high risk to both individuals and organizations.

4. Indicators of Compromise (IOCs)

4.1. Email-Based IOCs

IOC Type	Value
From Address	no-reply@access-accsecurity.com
Reply-To Address	sotrecognizd@gmail.com
Subject	Microsoft account unusual signin activity
Sender IP	89.144.44.2

4.2. Network & URL IOCs

IOC Type	Value
Domain	thebandalisty.com
URL	http://thebandalisty.com/track/...

4.3. Behavioural IOCs

Common triggers useful for SIEM detection rules:

- "reply-to mismatch"
- "domain flagged malicious"
- "phishing URL detected"
- "spoofed sender address"
- "impersonation of Microsoft"
- "urgent security alert style email"

5. Conclusion

This phishing email is confirmed to be a **true positive** phishing attempt based on:

- Mismatched and spoofed email headers
- Malicious sender IP reputation
- Malicious URLs flagged by threat intelligence
- Social engineering content and impersonation
- Credential harvesting intent

The investigation demonstrates how attackers use trust exploitation and urgency tactics to manipulate users.

Key learnings from this analysis:

- Email header analysis is crucial in identifying spoofing
- Threat intelligence platforms help validate malicious indicators
- Phishing campaigns often impersonate well-known brands
- URLs and domains must always be reputation-checked
- IOCs gathered can be used to strengthen SIEM detection and awareness training

This exercise strengthened my skills in email forensics, phishing identification, IOC extraction, and incident reporting.

References

- Peixoto, R. *EML Analyzer – Email Phishing Analysis Tool.* Available at: https://eml-analyzer.herokuapp.com
- Peixoto, R. *Phishing Pot – Open-source phishing email analysis toolkit.* GitHub Repository: https://github.com/rf-peixoto/phishing_pot
- *MXToolbox Email Header Analyzer – Email routing and header diagnostics.* Available at: https://mxtoolbox.com/Public/Tools/EmailHeaders.aspx
- *AbuseIPDB – IP Address Threat Intelligence & Abuse Reporting.* Available at: https://www.abuseipdb.com
- *VirusTotal – URL, Domain, and File Threat Intelligence.* Available at: https://www.virustotal.com
- *MITRE ATT&CK – Adversary Techniques & Tactics Knowledge Base.* Available at: https://attack.mitre.org

THANK YOU

Done by

AKSHAY R

Cybersecurity Intern

CyberSapiens